TÀI LIỆU ĐẶC TẢ KIẾN TRÚC KỸ THUẬT HỆ THỐNG CNTT & ĐÁM MÂY DOANH NGHIỆP
Mục 1. TỔNG QUAN KIẾN TRÚC HỆ THỐNG:
Hệ thống phần mềm lõi của doanh nghiệp được thiết kế theo mô hình Modular Monolith trên nền tảng container hóa Docker, cho phép mở rộng sang Microservices khi lưu lượng vượt ngưỡng 5000 requests/giây.
Ngôn ngữ lập trình chính phía Backend là Python 3.13 kết hợp FastAPI 0.115+, phía Frontend sử dụng React 18 với TypeScript 5.x và Tailwind CSS.

Hướng dẫn thi hành và áp dụng thực tiễn tại Trang 1:
Các đơn vị phòng ban, bộ phận chuyên môn, cán bộ quản lý và cá nhân có liên quan chịu trách nhiệm phổ biến, quán triệt và tổ chức thực hiện nghiêm túc các quy định nêu tại trang 1 của văn bản DAC TA KIEN TRUC KY THUAT CNTT & RAG. Trong quá trình triển khai thực tế tại doanh nghiệp và cơ sở đào tạo, mọi hồ sơ, chứng từ, biên bản đối chiếu và dữ liệu lưu trữ điện tử phải được lập đầy đủ, chính xác, minh bạch, tuân thủ đúng trình tự thủ tục, định mức kỹ thuật và thời hạn quy định. Trường hợp phát sinh vướng mắc hoặc tình huống đặc thù chưa được liệt kê chi tiết tại điều khoản này, bộ phận phụ trách phải lập báo cáo bằng văn bản trình cấp có thẩm quyền xem xét, phê duyệt phương án xử lý trên nguyên tắc bảo đảm quyền lợi hợp pháp của các bên, an toàn thông tin hệ thống và tuân thủ quy định hiện hành của pháp luật Việt Nam.

Mục 2. CAM KẾT MỨC ĐỘ DỊCH VỤ (SLA - SERVICE LEVEL AGREEMENT):
1. Độ sẵn sàng cam kết (Uptime SLA) đối với môi trường Production là 99.95% tính theo chu kỳ hằng tháng.
2. Thời gian ngừng hoạt động ngoài kế hoạch (Unplanned Downtime) tối đa cho phép không vượt quá 21 phút 54 giây trong một tháng.
3. Thời gian bảo trì định kỳ (Scheduled Maintenance Window) được thực hiện vào khung giờ từ 01:00 đến 03:00 sáng Chủ nhật tuần thứ hai của mỗi tháng và phải thông báo trước ít nhất 48 giờ.

Hướng dẫn thi hành và áp dụng thực tiễn tại Trang 2:
Các đơn vị phòng ban, bộ phận chuyên môn, cán bộ quản lý và cá nhân có liên quan chịu trách nhiệm phổ biến, quán triệt và tổ chức thực hiện nghiêm túc các quy định nêu tại trang 2 của văn bản DAC TA KIEN TRUC KY THUAT CNTT & RAG. Trong quá trình triển khai thực tế tại doanh nghiệp và cơ sở đào tạo, mọi hồ sơ, chứng từ, biên bản đối chiếu và dữ liệu lưu trữ điện tử phải được lập đầy đủ, chính xác, minh bạch, tuân thủ đúng trình tự thủ tục, định mức kỹ thuật và thời hạn quy định. Trường hợp phát sinh vướng mắc hoặc tình huống đặc thù chưa được liệt kê chi tiết tại điều khoản này, bộ phận phụ trách phải lập báo cáo bằng văn bản trình cấp có thẩm quyền xem xét, phê duyệt phương án xử lý trên nguyên tắc bảo đảm quyền lợi hợp pháp của các bên, an toàn thông tin hệ thống và tuân thủ quy định hiện hành của pháp luật Việt Nam.

Mục 3. CHỈ TIÊU HIỆU NĂNG PHẢN HỒI API (LATENCY BUDGET):
1. Đối với các RESTful API nghiệp vụ thông thường (CRUD tài liệu, lịch sử hội thoại): Độ trễ phân vị thứ 95 (p95 Latency) không vượt quá 200ms và p99 Latency không vượt quá 450ms.
2. Đối với luồng truy xuất ngữ nghĩa Vector (Semantic Retrieval trên ChromaDB với 10.000 Chunks): Thời gian tìm kiếm Top-5 vector phải nhỏ hơn 500ms.
3. Đối với luồng tổng hợp câu trả lời RAG toàn trình (End-to-End RAG Chat): Thời gian phản hồi p95 dưới 8.0 giây.

Hướng dẫn thi hành và áp dụng thực tiễn tại Trang 3:
Các đơn vị phòng ban, bộ phận chuyên môn, cán bộ quản lý và cá nhân có liên quan chịu trách nhiệm phổ biến, quán triệt và tổ chức thực hiện nghiêm túc các quy định nêu tại trang 3 của văn bản DAC TA KIEN TRUC KY THUAT CNTT & RAG. Trong quá trình triển khai thực tế tại doanh nghiệp và cơ sở đào tạo, mọi hồ sơ, chứng từ, biên bản đối chiếu và dữ liệu lưu trữ điện tử phải được lập đầy đủ, chính xác, minh bạch, tuân thủ đúng trình tự thủ tục, định mức kỹ thuật và thời hạn quy định. Trường hợp phát sinh vướng mắc hoặc tình huống đặc thù chưa được liệt kê chi tiết tại điều khoản này, bộ phận phụ trách phải lập báo cáo bằng văn bản trình cấp có thẩm quyền xem xét, phê duyệt phương án xử lý trên nguyên tắc bảo đảm quyền lợi hợp pháp của các bên, an toàn thông tin hệ thống và tuân thủ quy định hiện hành của pháp luật Việt Nam.

Mục 4. KIẾN TRÚC CƠ SỞ DỮ LIỆU QUAN HỆ (POSTGRESQL 16):
1. Hệ thống sử dụng PostgreSQL 16.4 chạy theo mô hình Primary - Standby Replication (1 node Primary ghi/đọc và 1 node Read Replica đồng bộ).
2. Bộ quản lý kết nối (Connection Pooling) sử dụng SQLAlchemy QueuePool kết hợp PgBouncer với thông số chuẩn: pool_size = 20 kết nối thường trực, max_overflow = 10 kết nối mở rộng và pool_recycle = 1800 giây.
3. Mọi khóa chính của các bảng dữ liệu nghiệp vụ đều sử dụng kiểu UUID v4 nhằm tránh lộ số lượng bản ghi tuần tự.

Hướng dẫn thi hành và áp dụng thực tiễn tại Trang 4:
Các đơn vị phòng ban, bộ phận chuyên môn, cán bộ quản lý và cá nhân có liên quan chịu trách nhiệm phổ biến, quán triệt và tổ chức thực hiện nghiêm túc các quy định nêu tại trang 4 của văn bản DAC TA KIEN TRUC KY THUAT CNTT & RAG. Trong quá trình triển khai thực tế tại doanh nghiệp và cơ sở đào tạo, mọi hồ sơ, chứng từ, biên bản đối chiếu và dữ liệu lưu trữ điện tử phải được lập đầy đủ, chính xác, minh bạch, tuân thủ đúng trình tự thủ tục, định mức kỹ thuật và thời hạn quy định. Trường hợp phát sinh vướng mắc hoặc tình huống đặc thù chưa được liệt kê chi tiết tại điều khoản này, bộ phận phụ trách phải lập báo cáo bằng văn bản trình cấp có thẩm quyền xem xét, phê duyệt phương án xử lý trên nguyên tắc bảo đảm quyền lợi hợp pháp của các bên, an toàn thông tin hệ thống và tuân thủ quy định hiện hành của pháp luật Việt Nam.

Mục 5. KIẾN TRÚC CƠ SỞ DỮ LIỆU VECTOR (CHROMADB & HNSW INDEX):
1. Các đoạn văn bản (Chunks) sau khi đi qua mô hình BAAI/bge-m3 sẽ sinh ra vector dày đặc (Dense Vector) có kích thước cố định 1024 chiều (1024 dimensions), kiểu số thực dấu phẩy động float32.
2. ChromaDB sử dụng thuật toán lập chỉ mục đồ thị HNSW (Hierarchical Navigable Small World) với hàm đo khoảng cách Cosine (hnsw:space = 'cosine').
3. Các siêu tham số HNSW chuẩn trong hệ thống: M = 16 (số liên kết hai chiều mỗi nút), ef_construction = 200 khi xây dựng chỉ mục và ef_search = 100 khi truy vấn.

Hướng dẫn thi hành và áp dụng thực tiễn tại Trang 5:
Các đơn vị phòng ban, bộ phận chuyên môn, cán bộ quản lý và cá nhân có liên quan chịu trách nhiệm phổ biến, quán triệt và tổ chức thực hiện nghiêm túc các quy định nêu tại trang 5 của văn bản DAC TA KIEN TRUC KY THUAT CNTT & RAG. Trong quá trình triển khai thực tế tại doanh nghiệp và cơ sở đào tạo, mọi hồ sơ, chứng từ, biên bản đối chiếu và dữ liệu lưu trữ điện tử phải được lập đầy đủ, chính xác, minh bạch, tuân thủ đúng trình tự thủ tục, định mức kỹ thuật và thời hạn quy định. Trường hợp phát sinh vướng mắc hoặc tình huống đặc thù chưa được liệt kê chi tiết tại điều khoản này, bộ phận phụ trách phải lập báo cáo bằng văn bản trình cấp có thẩm quyền xem xét, phê duyệt phương án xử lý trên nguyên tắc bảo đảm quyền lợi hợp pháp của các bên, an toàn thông tin hệ thống và tuân thủ quy định hiện hành của pháp luật Việt Nam.

Mục 6. TIÊU CHUẨN MÃ HÓA VÀ BẢO MẬT DỮ LIỆU (ENCRYPTION STANDARDS):
1. Bảo mật dữ liệu trên đường truyền (Encryption in Transit): Bắt buộc sử dụng giao thức TLS 1.3 (tối thiểu TLS 1.2) với bộ mã hóa ECDHE-RSA-AES256-GCM-SHA384 cho toàn bộ kết nối HTTPS và kết nối nội bộ tới cơ sở dữ liệu.
2. Bảo mật dữ liệu lưu trữ tĩnh (Encryption at Rest): Toàn bộ ổ đĩa lưu trữ tệp PDF/DOCX, phân vùng PostgreSQL và ChromaDB được mã hóa bằng chuẩn AES-256.
3. Mật khẩu người dùng bắt buộc băm bằng thuật toán Argon2id hoặc bcrypt với hệ số chi phí (cost factor) tối thiểu là 12.

Hướng dẫn thi hành và áp dụng thực tiễn tại Trang 6:
Các đơn vị phòng ban, bộ phận chuyên môn, cán bộ quản lý và cá nhân có liên quan chịu trách nhiệm phổ biến, quán triệt và tổ chức thực hiện nghiêm túc các quy định nêu tại trang 6 của văn bản DAC TA KIEN TRUC KY THUAT CNTT & RAG. Trong quá trình triển khai thực tế tại doanh nghiệp và cơ sở đào tạo, mọi hồ sơ, chứng từ, biên bản đối chiếu và dữ liệu lưu trữ điện tử phải được lập đầy đủ, chính xác, minh bạch, tuân thủ đúng trình tự thủ tục, định mức kỹ thuật và thời hạn quy định. Trường hợp phát sinh vướng mắc hoặc tình huống đặc thù chưa được liệt kê chi tiết tại điều khoản này, bộ phận phụ trách phải lập báo cáo bằng văn bản trình cấp có thẩm quyền xem xét, phê duyệt phương án xử lý trên nguyên tắc bảo đảm quyền lợi hợp pháp của các bên, an toàn thông tin hệ thống và tuân thủ quy định hiện hành của pháp luật Việt Nam.

Mục 7. XÁC THỰC VÀ PHÂN QUYỀN TRUY CẬP (AUTHENTICATION & RBAC):
1. Hệ thống sử dụng cơ chế xác thực không trạng thái bằng JSON Web Token (JWT) ký bằng thuật toán bất đối xứng RS256 (RSA 2048-bit).
2. Thời hạn hiệu lực của Access Token là 15 phút; thời hạn của Refresh Token là 07 ngày và được lưu trong HttpOnly, Secure, SameSite=Strict Cookie.
3. Khi người dùng đăng xuất hoặc đổi mật khẩu, Refresh Token cũ bị thu hồi ngay lập tức thông qua danh sách đen (Token Blacklist) lưu trên Redis.

Hướng dẫn thi hành và áp dụng thực tiễn tại Trang 7:
Các đơn vị phòng ban, bộ phận chuyên môn, cán bộ quản lý và cá nhân có liên quan chịu trách nhiệm phổ biến, quán triệt và tổ chức thực hiện nghiêm túc các quy định nêu tại trang 7 của văn bản DAC TA KIEN TRUC KY THUAT CNTT & RAG. Trong quá trình triển khai thực tế tại doanh nghiệp và cơ sở đào tạo, mọi hồ sơ, chứng từ, biên bản đối chiếu và dữ liệu lưu trữ điện tử phải được lập đầy đủ, chính xác, minh bạch, tuân thủ đúng trình tự thủ tục, định mức kỹ thuật và thời hạn quy định. Trường hợp phát sinh vướng mắc hoặc tình huống đặc thù chưa được liệt kê chi tiết tại điều khoản này, bộ phận phụ trách phải lập báo cáo bằng văn bản trình cấp có thẩm quyền xem xét, phê duyệt phương án xử lý trên nguyên tắc bảo đảm quyền lợi hợp pháp của các bên, an toàn thông tin hệ thống và tuân thủ quy định hiện hành của pháp luật Việt Nam.

Mục 8. GIỚI HẠN TẦN SUẤT GỌI API (RATE LIMITING & THROTTLING):
Để chống tấn công từ chối dịch vụ (DoS) và lạm dụng tài nguyên LLM, cổng Nginx và Middleware áp dụng thuật toán Token Bucket theo địa chỉ IP và User ID:
1. Nhóm API chung (GET /api/documents, GET /api/conversations): Tối đa 120 requests / phút / người dùng.
2. Nhóm API tải tệp (POST /api/documents/upload): Tối đa 10 requests / phút / người dùng; dung lượng tệp tối đa 20MB.
3. Nhóm API hỏi đáp AI (POST /api/chat): Tối đa 20 requests / phút / người dùng.

Hướng dẫn thi hành và áp dụng thực tiễn tại Trang 8:
Các đơn vị phòng ban, bộ phận chuyên môn, cán bộ quản lý và cá nhân có liên quan chịu trách nhiệm phổ biến, quán triệt và tổ chức thực hiện nghiêm túc các quy định nêu tại trang 8 của văn bản DAC TA KIEN TRUC KY THUAT CNTT & RAG. Trong quá trình triển khai thực tế tại doanh nghiệp và cơ sở đào tạo, mọi hồ sơ, chứng từ, biên bản đối chiếu và dữ liệu lưu trữ điện tử phải được lập đầy đủ, chính xác, minh bạch, tuân thủ đúng trình tự thủ tục, định mức kỹ thuật và thời hạn quy định. Trường hợp phát sinh vướng mắc hoặc tình huống đặc thù chưa được liệt kê chi tiết tại điều khoản này, bộ phận phụ trách phải lập báo cáo bằng văn bản trình cấp có thẩm quyền xem xét, phê duyệt phương án xử lý trên nguyên tắc bảo đảm quyền lợi hợp pháp của các bên, an toàn thông tin hệ thống và tuân thủ quy định hiện hành của pháp luật Việt Nam.

Mục 9. CHÍNH SÁCH SAO LƯU VÀ PHỤC HỒI THẢM HỌA (BACKUP, RPO & RTO):
1. Chỉ tiêu điểm phục hồi dữ liệu (RPO - Recovery Point Objective): Tối đa 15 phút (nhờ cơ chế lưu trữ liên tục Write-Ahead Logging WAL của PostgreSQL lên kho lưu trữ đối tượng S3).
2. Chỉ tiêu thời gian phục hồi hệ thống (RTO - Recovery Time Objective): Tối đa 60 phút kể từ khi kích hoạt quy trình chuyển đổi dự phòng (Failover).
3. Lịch sao lưu định kỳ: Sao lưu toàn phần (Full Backup) tự động lúc 02:00 sáng hằng ngày; bản sao lưu hằng ngày được lưu giữ trong 30 ngày và bản sao lưu hằng tháng được lưu giữ trong 12 tháng.

Hướng dẫn thi hành và áp dụng thực tiễn tại Trang 9:
Các đơn vị phòng ban, bộ phận chuyên môn, cán bộ quản lý và cá nhân có liên quan chịu trách nhiệm phổ biến, quán triệt và tổ chức thực hiện nghiêm túc các quy định nêu tại trang 9 của văn bản DAC TA KIEN TRUC KY THUAT CNTT & RAG. Trong quá trình triển khai thực tế tại doanh nghiệp và cơ sở đào tạo, mọi hồ sơ, chứng từ, biên bản đối chiếu và dữ liệu lưu trữ điện tử phải được lập đầy đủ, chính xác, minh bạch, tuân thủ đúng trình tự thủ tục, định mức kỹ thuật và thời hạn quy định. Trường hợp phát sinh vướng mắc hoặc tình huống đặc thù chưa được liệt kê chi tiết tại điều khoản này, bộ phận phụ trách phải lập báo cáo bằng văn bản trình cấp có thẩm quyền xem xét, phê duyệt phương án xử lý trên nguyên tắc bảo đảm quyền lợi hợp pháp của các bên, an toàn thông tin hệ thống và tuân thủ quy định hiện hành của pháp luật Việt Nam.

Mục 10. QUản LÝ NHẬT KÝ HỆ THỐNG VÀ GIÁM SÁT (LOGGING & MONITORING):
1. Toàn bộ nhật ký ứng dụng (Application Logs) được xuất theo định dạng chuẩn JSON (Structured JSON Logging) bao gồm: timestamp, level, trace_id, endpoint, latency_ms và status_code.
2. Tuyệt đối không ghi (Masking/Redaction) các thông tin nhạy cảm như mật khẩu, API Key, JWT Token hoặc số căn cước công dân vào tệp nhật ký.
3. Thời gian lưu trữ nhật ký trực tuyến (Hot Storage trên Elasticsearch/Loki) là 90 ngày và lưu trữ lạnh (Cold Archive) là 365 ngày.

Hướng dẫn thi hành và áp dụng thực tiễn tại Trang 10:
Các đơn vị phòng ban, bộ phận chuyên môn, cán bộ quản lý và cá nhân có liên quan chịu trách nhiệm phổ biến, quán triệt và tổ chức thực hiện nghiêm túc các quy định nêu tại trang 10 của văn bản DAC TA KIEN TRUC KY THUAT CNTT & RAG. Trong quá trình triển khai thực tế tại doanh nghiệp và cơ sở đào tạo, mọi hồ sơ, chứng từ, biên bản đối chiếu và dữ liệu lưu trữ điện tử phải được lập đầy đủ, chính xác, minh bạch, tuân thủ đúng trình tự thủ tục, định mức kỹ thuật và thời hạn quy định. Trường hợp phát sinh vướng mắc hoặc tình huống đặc thù chưa được liệt kê chi tiết tại điều khoản này, bộ phận phụ trách phải lập báo cáo bằng văn bản trình cấp có thẩm quyền xem xét, phê duyệt phương án xử lý trên nguyên tắc bảo đảm quyền lợi hợp pháp của các bên, an toàn thông tin hệ thống và tuân thủ quy định hiện hành của pháp luật Việt Nam.

Mục 11. HỆ THỐNG CẢNH BÁO TỰ ĐỘNG (PROMETHEUS & GRAFANA ALERTING):
Hệ thống thu thập chỉ số hạ tầng mỗi 15 giây qua Prometheus và phát cảnh báo tức thì qua Slack/PagerDuty khi vượt các ngưỡng sau:
1. Mức sử dụng CPU hoặc RAM của bất kỳ container nào vượt quá 85% liên tục trong 05 phút.
2. Dung lượng ổ đĩa lưu trữ (/app/storage) đạt mức 80% dung lượng tối đa.
3. Tỷ lệ lỗi máy chủ (HTTP 5xx Error Rate) vượt quá 1.0% tổng số requests trong cửa sổ 05 phút.

Hướng dẫn thi hành và áp dụng thực tiễn tại Trang 11:
Các đơn vị phòng ban, bộ phận chuyên môn, cán bộ quản lý và cá nhân có liên quan chịu trách nhiệm phổ biến, quán triệt và tổ chức thực hiện nghiêm túc các quy định nêu tại trang 11 của văn bản DAC TA KIEN TRUC KY THUAT CNTT & RAG. Trong quá trình triển khai thực tế tại doanh nghiệp và cơ sở đào tạo, mọi hồ sơ, chứng từ, biên bản đối chiếu và dữ liệu lưu trữ điện tử phải được lập đầy đủ, chính xác, minh bạch, tuân thủ đúng trình tự thủ tục, định mức kỹ thuật và thời hạn quy định. Trường hợp phát sinh vướng mắc hoặc tình huống đặc thù chưa được liệt kê chi tiết tại điều khoản này, bộ phận phụ trách phải lập báo cáo bằng văn bản trình cấp có thẩm quyền xem xét, phê duyệt phương án xử lý trên nguyên tắc bảo đảm quyền lợi hợp pháp của các bên, an toàn thông tin hệ thống và tuân thủ quy định hiện hành của pháp luật Việt Nam.

Mục 12. PHÂN LOẠI VÀ THỜI GIAN PHẢN ỨNG SỰ CỐ (INCIDENT RESPONSE SLA):
- Mức P1 (Critical - Hệ thống ngừng hoạt động hoàn toàn hoặc rò rỉ dữ liệu): Thời gian phản hồi đầu tiên trong vòng 15 phút, cập nhật trạng thái mỗi 30 phút, mục tiêu khắc phục trong 02 giờ.
- Mức P2 (High - Một phân hệ chính như Upload hoặc Chat LLM bị lỗi nặng): Thời gian phản hồi trong 30 phút, mục tiêu khắc phục trong 04 giờ.
- Mức P3 (Medium - Lỗi chức năng phụ, có cách xử lý tạm thời): Thời gian phản hồi trong 04 giờ làm việc, khắc phục trong 24 giờ.
- Mức P4 (Low - Lỗi hiển thị giao diện nhỏ): Phản hồi trong 24 giờ, xử lý ở bản phát hành Sprint kế tiếp.

Hướng dẫn thi hành và áp dụng thực tiễn tại Trang 12:
Các đơn vị phòng ban, bộ phận chuyên môn, cán bộ quản lý và cá nhân có liên quan chịu trách nhiệm phổ biến, quán triệt và tổ chức thực hiện nghiêm túc các quy định nêu tại trang 12 của văn bản DAC TA KIEN TRUC KY THUAT CNTT & RAG. Trong quá trình triển khai thực tế tại doanh nghiệp và cơ sở đào tạo, mọi hồ sơ, chứng từ, biên bản đối chiếu và dữ liệu lưu trữ điện tử phải được lập đầy đủ, chính xác, minh bạch, tuân thủ đúng trình tự thủ tục, định mức kỹ thuật và thời hạn quy định. Trường hợp phát sinh vướng mắc hoặc tình huống đặc thù chưa được liệt kê chi tiết tại điều khoản này, bộ phận phụ trách phải lập báo cáo bằng văn bản trình cấp có thẩm quyền xem xét, phê duyệt phương án xử lý trên nguyên tắc bảo đảm quyền lợi hợp pháp của các bên, an toàn thông tin hệ thống và tuân thủ quy định hiện hành của pháp luật Việt Nam.

Mục 13. QUY TRÌNH KIỂM THỬ VÀ TÍCH HỢP LIÊN TỤC (CI/CD PIPELINE):
Mọi Pull Request gửi vào nhánh main trên GitHub bắt buộc phải vượt qua tự động 04 cổng kiểm tra trên GitHub Actions:
1. Kiểm tra định dạng và quy chuẩn mã nguồn (Ruff Linter cho Python, ESLint & TypeScript tsc --noEmit cho Frontend).
2. Chạy toàn bộ bộ kiểm thử đơn vị và tích hợp (Pytest) với độ bao phủ mã nguồn (Code Coverage) của tầng dịch vụ lõi đạt tối thiểu 80%.
3. Quét lỗ hổng bảo mật thư viện phụ thuộc (Trivy / pip-audit / npm audit) không có lỗ hổng mức Critical.
4. Đóng gói thử nghiệm thành công Docker Image cho cả Backend và Frontend.

Hướng dẫn thi hành và áp dụng thực tiễn tại Trang 13:
Các đơn vị phòng ban, bộ phận chuyên môn, cán bộ quản lý và cá nhân có liên quan chịu trách nhiệm phổ biến, quán triệt và tổ chức thực hiện nghiêm túc các quy định nêu tại trang 13 của văn bản DAC TA KIEN TRUC KY THUAT CNTT & RAG. Trong quá trình triển khai thực tế tại doanh nghiệp và cơ sở đào tạo, mọi hồ sơ, chứng từ, biên bản đối chiếu và dữ liệu lưu trữ điện tử phải được lập đầy đủ, chính xác, minh bạch, tuân thủ đúng trình tự thủ tục, định mức kỹ thuật và thời hạn quy định. Trường hợp phát sinh vướng mắc hoặc tình huống đặc thù chưa được liệt kê chi tiết tại điều khoản này, bộ phận phụ trách phải lập báo cáo bằng văn bản trình cấp có thẩm quyền xem xét, phê duyệt phương án xử lý trên nguyên tắc bảo đảm quyền lợi hợp pháp của các bên, an toàn thông tin hệ thống và tuân thủ quy định hiện hành của pháp luật Việt Nam.

Mục 14. PHÒNG CHỐNG TẤN CÔNG ĐẶC THÙ TRÊN ỨNG DỤNG LLM & RAG:
1. Chống Indirect Prompt Injection: Toàn bộ văn bản trích xuất từ tài liệu của người dùng phải được đặt trong cặp thẻ phân tách <document_context>...</document_context> kèm chỉ thị rõ đây chỉ là dữ liệu thụ động.
2. Chống Hallucination & Bịa nguồn trích dẫn: Hệ thống áp dụng cơ chế xác thực trích dẫn 2 lớp (Regex + đối chiếu bảng source_map tại Backend) và giữ tham số Temperature trong khoảng 0.1 - 0.2.
3. Chống Path Traversal & Malicious File Upload: Kiểm tra chữ ký byte đầu tệp (Magic Bytes %PDF- cho PDF và PK\x03\x04 cho DOCX), đổi tên tệp lưu trữ sang UUID ngẫu nhiên.

Hướng dẫn thi hành và áp dụng thực tiễn tại Trang 14:
Các đơn vị phòng ban, bộ phận chuyên môn, cán bộ quản lý và cá nhân có liên quan chịu trách nhiệm phổ biến, quán triệt và tổ chức thực hiện nghiêm túc các quy định nêu tại trang 14 của văn bản DAC TA KIEN TRUC KY THUAT CNTT & RAG. Trong quá trình triển khai thực tế tại doanh nghiệp và cơ sở đào tạo, mọi hồ sơ, chứng từ, biên bản đối chiếu và dữ liệu lưu trữ điện tử phải được lập đầy đủ, chính xác, minh bạch, tuân thủ đúng trình tự thủ tục, định mức kỹ thuật và thời hạn quy định. Trường hợp phát sinh vướng mắc hoặc tình huống đặc thù chưa được liệt kê chi tiết tại điều khoản này, bộ phận phụ trách phải lập báo cáo bằng văn bản trình cấp có thẩm quyền xem xét, phê duyệt phương án xử lý trên nguyên tắc bảo đảm quyền lợi hợp pháp của các bên, an toàn thông tin hệ thống và tuân thủ quy định hiện hành của pháp luật Việt Nam.

Mục 15. CẤU HÌNH TRIỂN KHAI CONTAINER (DOCKER COMPOSE RESOURCE LIMITS):
Trong môi trường Production tiêu chuẩn, giới hạn tài nguyên cho 03 dịch vụ trong docker-compose.yml được quy định như sau:
1. Dịch vụ db (postgres:16-alpine): Giới hạn 2 vCPU, 2GB RAM, gắn Named Volume postgres_data.
2. Dịch vụ backend (Python 3.13 + FastAPI + BAAI/bge-m3): Giới hạn 4 vCPU, 6GB RAM, gắn Volume lưu trữ bền vững cho /app/storage/uploads và /app/storage/chroma_db.
3. Dịch vụ frontend (Nginx 1.27-alpine phục vụ bản build React): Giới hạn 1 vCPU, 512MB RAM, mở cổng 80/443.

Hướng dẫn thi hành và áp dụng thực tiễn tại Trang 15:
Các đơn vị phòng ban, bộ phận chuyên môn, cán bộ quản lý và cá nhân có liên quan chịu trách nhiệm phổ biến, quán triệt và tổ chức thực hiện nghiêm túc các quy định nêu tại trang 15 của văn bản DAC TA KIEN TRUC KY THUAT CNTT & RAG. Trong quá trình triển khai thực tế tại doanh nghiệp và cơ sở đào tạo, mọi hồ sơ, chứng từ, biên bản đối chiếu và dữ liệu lưu trữ điện tử phải được lập đầy đủ, chính xác, minh bạch, tuân thủ đúng trình tự thủ tục, định mức kỹ thuật và thời hạn quy định. Trường hợp phát sinh vướng mắc hoặc tình huống đặc thù chưa được liệt kê chi tiết tại điều khoản này, bộ phận phụ trách phải lập báo cáo bằng văn bản trình cấp có thẩm quyền xem xét, phê duyệt phương án xử lý trên nguyên tắc bảo đảm quyền lợi hợp pháp của các bên, an toàn thông tin hệ thống và tuân thủ quy định hiện hành của pháp luật Việt Nam.

Mục 16. QUY ĐỊNH QUẢN LÝ KHÓA BÍ MẬT VÀ VÒNG ĐỜI DỮ LIỆU (SECRET & DATA RETENTION):
1. Tuyệt đối không lưu khóa LLM_API_KEY hoặc mật khẩu cơ sở dữ liệu trực tiếp trong mã nguồn Git; mọi khóa bí mật phải được truyền qua biến môi trường (.env hoặc Vault).
2. Chu kỳ xoay vòng khóa bí mật (Secret Rotation): Khóa API và mật khẩu cơ sở dữ liệu Production phải được xoay vòng định kỳ mỗi 90 ngày một lần.
3. Khi người dùng thực hiện lệnh DELETE /api/documents/{id}, hệ thống phải xóa đồng bộ ngay lập tức ở cả 3 nơi: vector trong ChromaDB, tệp vật lý trên ổ đĩa và bản ghi trong PostgreSQL.

Hướng dẫn thi hành và áp dụng thực tiễn tại Trang 16:
Các đơn vị phòng ban, bộ phận chuyên môn, cán bộ quản lý và cá nhân có liên quan chịu trách nhiệm phổ biến, quán triệt và tổ chức thực hiện nghiêm túc các quy định nêu tại trang 16 của văn bản DAC TA KIEN TRUC KY THUAT CNTT & RAG. Trong quá trình triển khai thực tế tại doanh nghiệp và cơ sở đào tạo, mọi hồ sơ, chứng từ, biên bản đối chiếu và dữ liệu lưu trữ điện tử phải được lập đầy đủ, chính xác, minh bạch, tuân thủ đúng trình tự thủ tục, định mức kỹ thuật và thời hạn quy định. Trường hợp phát sinh vướng mắc hoặc tình huống đặc thù chưa được liệt kê chi tiết tại điều khoản này, bộ phận phụ trách phải lập báo cáo bằng văn bản trình cấp có thẩm quyền xem xét, phê duyệt phương án xử lý trên nguyên tắc bảo đảm quyền lợi hợp pháp của các bên, an toàn thông tin hệ thống và tuân thủ quy định hiện hành của pháp luật Việt Nam.